

密码学综述

郑东, 赵庆兰, 张应辉

(西安邮电大学 无线网络安全技术国家工程实验室, 陕西 西安 710121)

摘要: 由密码学的基本概念出发, 介绍密码学及其应用的最新发展状况, 包括公钥密码体制及其安全理论、各种密码协议及其面临的攻击, 并对安全协议的分析方法进行概述。根据当今的发展状况指出密码学的发展趋势和未来的研究方向。

关键词: 信息安全; 密码学; 数字签名; 公钥密码体制; 私钥密码体制

中图分类号: TN918

文献标识码: A

文章编号: 2095-6533(2013)06-0001-10

A brief overview on cryptography

ZHENG Dong, ZHAO Qinglan, ZHANG Yinghui

(National Engineering Laboratory for Wireless Security, Xi'an University of Posts and Telecommunications, Xi'an 710121, China)

Abstract: In this paper, some basic concepts of cryptography are introduced. The latest development of cryptography and its applications are explained, including the public key cryptosystems, security theories, and various kinds of cryptographic protocols together with potential attacks. In addition, methods of security analysis for cryptographic protocols are summarized. Our own views on the development and future research directions of cryptography are also proposed.

Keywords: information security, cryptography, digital signature, public key cryptosystem, private key cryptosystem

密码学是一门非常古老的学科, 早期的密码技术是把人们能够读懂的消息变换成不易读懂的信息用来隐藏信息内容, 使得窃听者无法理解消息的内容, 同时又能够让合法用户把变换的结果还原成能够读懂的消息。密码学的发展大致可以分为 4 个阶段。

手工阶段的密码技术可以追溯到几千年以前, 这个时期的密码技术相对来说是非常简单的。可以说密码技术是伴随着人类战争的出现而出现的。早期的简单密码主要体现在实现方式上, 即通过替换或者换位进行密码变换, 其中比较著名的包括法国 Vigenere 密码, 古罗马 Caesar 密码等。尽管密码学技术与其它学科一样在不断向前发展, 但在第一次世界大战之前, 很少有公开的密码学文献出现。

一个密码算法的安全性往往是就一定的时间阶段而言的, 与人类当时的科技水平息息相关。

随着人类计算水平的提高, 针对密码的破译水平也突飞猛进, 因此密码技术也必须与时俱进, 不断发展。人类对于密码算法的安全性有着越来越高的要求, 这往往导致所设计的密码算法的复杂度急剧增大。在实际应用中, 一个密码算法效率越高越好, 因此人们就采用了机械方法以实现更加复杂的密码算法, 改进加解密手段。20 世纪初就出现了不少专用密码机, 比如 Colossus, 该密码机是由英国人 Turing 所设计的。

随着通信、电子和计算机等技术的发展, 密码学得到前所未有的系统发展。1949 年, Shannon 发表了“保密系统的通信理论”^[1], 给出了密码学的数学基础, 证明了一次一密密码系统的完善保密性。由于各种原因, 从 1949 年到 1967 年, 全世界的密码学文献几乎为零, 尽管密码技术一直在发展。直到

收稿日期: 2013-10-24

基金项目: 国家自然科学基金资助项目(60170249, 61272037); 陕西省自然科学基金资助项目(2013JZ020); 教育部博士点基金资助项目(20100073110060)

作者简介: 郑东(1964—), 男, 博士, 教授, 博导, 从事密码学和云计算安全研究。E-mail: zhengdong@xupt.edu.cn

赵庆兰(1981—), 女, 讲师, 博士研究生, 研究方向为密码学。E-mail: qlz@snnu.edu.cn

20世纪70年代初期,IBM提出Feistel网络并发表了在分组密码方面的研究报告,密码学才开始呈现出民间研究的前兆。

随着社会的发展,不管是政府还是普通老百姓都对信息的安全有了更多的认识,信息安全需求也不断增长。在这一背景下,20世纪70年代末,数据加密标准(Data Encryption Standard, DES)算法由美国政府确定,其具体的加密细节也被公开,从而使得基于DES加密的安全性只依赖于对密钥的保密。在1976年,Diffie和Hellman提出了“密码学新方向”^[2],开辟了公钥密码技术理论,使得密钥协商、数字签名等密码问题有了新的解决方法,也为密码学的广泛应用奠定了基础。

手工阶段和机械阶段使用的密码技术可以称为古典密码技术,主要采用简单的替换或置换技术。DES的公布与公钥密码技术问世标志密码学进入高速发展的现代密码学时代。

密码技术不但可以用于对网上所传送的数据进行加解密,而且也可以用于认证,进行数字签名^[3-5],以及关于完整性、安全套接层(Security Socket Layer, SSL)、安全电子交易(Secure Electronic Transaction, SET)等的安全通信标准和网络协议安全性标准中。

对于密码而言,其最基本的功能在于通过变换将明文消息变换成只有合法者才可以恢复的密文。信息的加密保护涉及到传输信息和存储信息两个方面,其中存储面临的安全问题更大。

所谓数字证书可以看作是“电子身份证”,可用于保证网络的正常运行。在网络通讯中,数字证书通过一系列数据来标志通讯各方的身份信息。现在交互式询问回答的应用很广泛,在询问和回答的过程中利用密码技术对消息进行加密,特别是基于密码的带中央处理器(Central Processing Unit, CPU)的智能卡,其安全性特别好。在电子商务系统中,所有参与活动的实体都要依赖于数字证书来证明自己的身份。

作为生成报文“数字指纹”的一个重要方法,“报文摘要”算法有着非常重要的作用。近年来,数字指纹受到了极大关注,已经成为现代密码学的一个重要研究方向。

为了防止消息在传输过程中被有意或无意的篡改,可以通过密码技术对消息进行处理,以得到消息的验证码并附在消息之后一起发送,实现对发送信息的验证,这在票据防伪中有重要作用。

信息时代的到来加速了电子数据对我们过去

所依赖的个人特征的替代,数字签名有两方面的作用,一是基于自己的签名具有不可否认性,从而可以确定文件已经签署的事实;二是由于签名难以伪造,从而确定了文件的真实性。

1 密码学基本概念与分类

1.1 密码学的基本概念

1.1.1 密码编码学

把来自信息源的可理解的原始消息变换成不可理解的消息,同时又可恢复到原消息的方法和原理的一门科学。

1.1.2 密码分析学

在不知道关于密钥的任何信息这一情况下,利用各种技术手段,试图通过密文来得到明文或密钥的全部信息或部分信息。密码分析也称为对密码体制的攻击。

按照攻击者是否对通信作干扰,密码分析可分为被动攻击和主动攻击2类。所谓被动攻击是指,攻击者仅是利用截获的密文及公开的算法,分析明文或密钥,不对通信作干扰。所谓主动攻击是指,攻击者通过对通信线路进行干扰,如引入新的密文,重复传播旧的密文,替换合法密文等,再对截获的密文进行分析。

按照攻击者掌握的知识条件,密码分析可分为唯密文攻击、已知明文攻击、选择明文攻击和选择密文攻击4类。所谓唯密文攻击是指,攻击者只知道一个要攻击的密文(通常包含消息的上下文)。所谓已知明文攻击是指,攻击者知道一些明文/密文对,若一个密码系统能够抵抗这种攻击,合法的接收者就不需要销毁已解密的明文。所谓选择明文攻击是指,攻击者可以选择一些明文及对应的密文(公钥密码体制必需能够抵抗这种攻击)。所谓选择密文攻击是指,攻击者可以选择一些密文并得到相应的明文。

1.2 密码体制的分类

通常,密码体制分为对称密码体制与非对称密码体制,而非对称密码体制往往又称为公钥密码体制。图1给出了密码体制的基本模型^[6-7]。

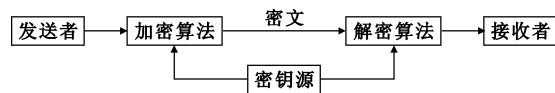


图1 密码体制的基本模型

在图1中,消息发送者从密钥源得到密钥,通过加密算法对消息进行加密得到密文,接收者收到密文后,利用从密钥源得到的密钥,通过解密算法对

密文进行解密, 得到原始消息。

1.2.1 对称密码体制

就对称密码体制而言, 除了算法公开外, 还有一个特点就是加密密钥和解密密钥可以比较容易的互相推导出来。对称密码体制按其对于明文的处理方式, 可分为序列密码算法和分组密码算法。自 20 世纪 70 年代中期, 美国首次公布了分组密码加密标准 DES 之后, 分组密码开始迅速发展, 使得世界各国的密码技术差距缩小, 也使得密码技术进入了突飞猛进的阶段, 典型的分组密码体制有 DES、3DES、国际数据加密算法 (International Data Encryption Algorithm, IDEA)、高级数据加密标准 (Advanced Encryption Standard, AES) 等。对称加密的流程如图 2 所示。

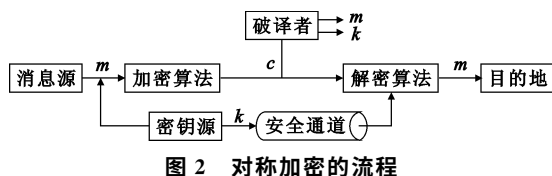


图 2 对称加密的流程

1.2.2 公钥密码体制

公钥密码体制问世不久, Merkle 也于 1978 独立提出这一体制。该密码体制的诞生可以说是密码学的一次“革命”, 公钥密码体制解决了对称密码算法在应用中的致命缺陷, 即密钥分配问题。就公钥密码体制而言, 除了加密算法公开外, 其具有不同的加密密钥和解密密钥, 加密密钥是公开的 (称作公钥), 解密密钥是保密的 (称作私钥), 且不能够从公钥推出私钥, 或者说从公钥推出私钥在计算上是“困难”的。这里“困难”是计算复杂性理论中的概念。

公钥密码技术的出现使得密码学得到了空前发展。在公钥密码出现之前, 密码主要应用于政府、外交、军事等部门, 如今密码在民用领域也得到了广泛应用。1977 年, 为了解决基于公开信道来传输 DES 算法的对称密钥这一公开难题, Rivest、Shamir 和 Adleman 提出了著名的公钥密码算法 RSA, 该算法的命名就是采用了三位发明者姓氏的首字母。RSA 公钥密码技术的提出, 不但很好的解决了基于公开信道的密钥分发问题, 而且还可以实现对电文信息的数字签名, 防止针对电文的抵赖以及否认。特别地, 利用数字签名技术, 我们也可以很容易发现潜在的攻击者对电文进行的非法篡改, 进而实现了信息的完整性保护。公钥密码体制中的典型算法除了 RSA 外, 还有椭圆曲线密码 (Elliptic Curve Cryptography, ECC)、Rabin、ElGamal 和数论研究单位算法 (Number Theory Research

Unit, NTRU) 等^[8]。

公开密钥特别适用于 Web 商务这样的业务需求。公开密钥有一个非常吸引人的优点: 即使一个用户不认识另一个实体, 但是只要其服务器确信这个实体的认证中心 (Certification Authority, CA) 是可信的, 就可以实现安全通信。例如, 在利用信用卡消费时, 根据客户 CA 的发行机构的可信度, 服务方对自己的资源进行授权。在任何一个国家, 由其他国家的公司充当 CA 都是非常危险的, 目前国内外尚没有可以完全信任的 CA 机构。然而, 在效率方面, 公钥密码体制远远不如对称密码体制, 其处理速度比较慢。因此在实际应用中, 往往是把公钥技术和私钥技术结合起来使用, 即利用公开密钥实现通信双方间的对称密钥传递, 而用对称密钥来加解密实际传输的数据。公钥加密的流程如图 3 所示。

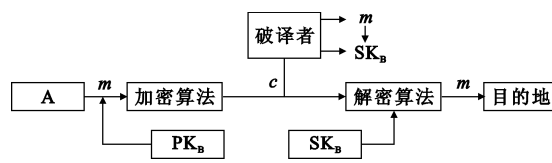


图 3 公钥加密的流程

在公钥密码体制中, 加解密密钥不同, 作为信息发送者, 加密者利用解密者的公钥信息加密, 在收到密文后, 解密者基于自己的私钥进行解密, 以恢复原始消息。公钥密码体制的优点是密钥分发相对容易, 密钥管理简单, 可以有效地实现数字签名。

1.3 密码分析学

所谓密码分析学主要研究在已知密码算法的条件下, 不需要密钥, 如何由加密得到的密文推导出明文或密钥的相关信息。随着密码算法设计技术的发展, 密码分析技术也得到了深入的研究。迄今为止, 已经有很多攻击密码技术的方法: 强力攻击、插值攻击、能量分析、线性密码分析、差分密码分析等, 同时还有一些对哈希 (Hash) 函数的分析技术、对伪随机序列的分析技术等。

1.3.1 强力攻击

强力攻击包括查表攻击, 时间-存储权衡攻击, 字典攻击以及穷举搜索攻击。对于任何一种分组密码来说, 强力攻击都是适用的。特别地, 这种攻击方法的复杂度仅仅取决于密钥和分组的长度。更严格地讲, 这种攻击技术的时间复杂度只取决于分组密码算法的效率, 如存储大小, 密钥扩展速度, 加密和解密的速度等。

1.3.2 线性密码分析

作为一种已知明文攻击方法, 线性密码分析方

法^[9]的本质思想在于,通过将一个给定的密码算法有效且线性近似地表示出来以实现破译。现有密码分析技术也得到了一定的推广。目前,利用已知明文,16轮DES系统已可以通过线性密码分析进行破译,在某些情况下甚至可以实现唯密文攻击。针对数据加密标准DES系统的主要攻击包括强力攻击手段,差分密码分析等。就16轮DES密码系统而言,不管是差分密码分析还是线性密码分析方法,需要用到的明文太多,因此效率比较低。为了提高攻击效率,可以结合差分密码分析和线性密码分析技术,即差分-线性密码分析技术。

1.3.3 差分密码分析

1990年,以色列密码学家 Biham 和 Shamir 提出了差分密码分析技术^[10-13]。差分密码分析特别适用于迭代密码。差分密码分析的本质思想在于,通过分析相应明文对差值和密文对差值之间的相互影响关系,来得到密钥的一些比特信息。对于差分密码分析也有很多推广,其中比较常见的包括高阶差分密码分析等。

2 公钥密码体制及其安全理论

公钥加密体制的思想是找到一种密码体制,其加密算法与解密算法不同,同时,利用加密算法推导出解密算法在计算上是困难的,这样加密密钥就能够以一种比较容易的方法长久的公布出去(避免了对称密钥需要安全信道)。公钥密码体制不能够提供无条件安全。实际上,一个攻击者完全可以在得到一个密文后,尝试着对大量明文逐一进行加密直到出现一样的密文,此时对应的明文就是要破译的结果。

就公钥密码系统而言,其主要特点在于加密密钥公开,解密密钥保密,二者具有对应关系,但是基于公开密钥很难推导或者求出解密密钥,其安全基础是“单向函数”。函数 $f(x)$ 如果满足:给定输入变量 x ,计算 $f(x)$ 容易,而给定 $f(x)$,计算 x 是困难的,则被称为单向函数,这里的“容易”和“困难”的含义是复杂性理论中的定义。从密码学的角度,上述两条性质已经能够用来构造密码算法。

2.1 公钥密码体制基于的数学难题

如前所说,目前大多数公钥密码算法(公钥加密体制和数字签名体制等)都是基于某个数学难题。

(1) 离散对数问题

设 F_p 是一有限域, p 是一素数, g 是其生成元,给定 $y \in F_p$,寻找 $0 < x \leq p$ 使得

$$y = g^x.$$

满足上式的整数称为 y 关于 g 的离散对数。如 ElGamal 加密体制与数字签名体制。一般情况下,在 m 阶群中计算离散对数问题的复杂度接近于分解 m 的复杂度。更多的算法可以参考文^[14]。

(2) 一般线性码的译码问题

给定一个 $r \times n$ 矩阵 H , 字 $s \in F_2^n$ 及整数 $w > 0$, 是否存在字 $x \in F_2^n$ 满足

$$Hx^T = s$$

且重量小于 w 。如 McEliece 密码体制^[15]。

(3) 基于格的困难问题

其一是格上最短向量问题 (Shortest Vector Problem, SVP)。给定一个 n 维格 L 及 L 上的一组基 B , 寻找向量 $v \in L$ 使得 v 的长度 $\|v\|$ 最短, 通常用 $\lambda(L)$ 表示 L 上的最短向量长度。

其二是格上最近向量问题 (Closest Vector Problem, CVP)。给定一个 n 维格 L , L 上的一组基 B 及向量 $\alpha \in L$, 寻找向量 $v \in L$ 使得 $\|v - \alpha\|$ 最小。基于格上困难问题的密码体制有 NTRU 加密体制与签名体制。

(4) 椭圆曲线上的离散对数问题

设 P 和 Q 是椭圆曲线上的点, 给定 P 和 Q , 寻找方程

$$Q = kP$$

的解 k 。基于椭圆曲线上的离散对数问题的密码体制有 ECC-ElGamal 体制等。

(5) 基于双线性对的困难问题

设 G_1 和 G_2 是两个 q 阶的循环群, G_1 记作加法群, G_2 记作乘法群。一个双线性对

$$e: G_1 \times G_1 \rightarrow G_2$$

是一个满足双线性性、非退化性和可计算性的双线性映射。双线性性是指, 设 $P, Q \in G_1$, $a, b \in \mathbb{Z}_q$, 有

$$e(aP, bQ) = e(P, Q)^{ab}.$$

非退化性是指, 对每一个 $P \in G_1^*$, 总存在 $Q \in G_1$, 使得 $e(P, Q) \neq 1$ 。可计算性是指, 给定 $P, Q \in G_1$, 存在一个有效算法可以计算 $e(P, Q)$ 。

双线性 Diffie-Hellman 问题 (Bilinear Diffie-Hellman Problem, BDHP) 是指, 给定 P, aP, bP, cP , 计算 $e(P, P)^{abc}$ 。在有些群上计算 BDHP 是困难问题。双线性 Diffie-Hellman 假设是指双线性 Diffie-Hellman 问题的求解是困难的。基于双线性对问题的密码体制有基于身份的密码体制 (Identity Based Encryption, IBE) 等^[16-17]。

(6) 基于多变量问题

多变量公钥体制的构造主要基于多向量二次方程 (Multivariate Quadratic, MQ) 问题^[18] 及多项式同构 (Isomorphism of Polynomials, IP) 问题^[19]

的难解性。

MQ 问题是指, 给定有限域 F_q 上的 n 个变元 m 个方程式的非线性多元二次方程组

$$\begin{cases} p_1(x_1, x_2, \dots, x_n) = y_1, \\ p_2(x_1, x_2, \dots, x_n) = y_2, \\ \dots\dots\dots \\ p_m(x_1, x_2, \dots, x_n) = y_m, \end{cases}$$

通常 $q > 2$, 每个多项式的形式为

$$p_i(x_1, x_2, \dots, x_n) = \sum_{1 \leq j \leq k \leq n} \gamma_{ijk} x_j x_k + \sum_{j=1}^n \beta_{ij} x_j + \alpha_i,$$

求解该方程组的问题称为 MQ 问题。已经有结论证明即使是在最小的域 F_2 上, MQ 问题为非确定性多项式求解 (Non-Deterministic Polynomial, NP) 问题。

IP 问题是指, 设 (P) 和 (Q) 为有限域 F_q 上随机的 n 元 m 个方程的多变量方程组, 且 (P) 和 (Q) 同构, 则有

$$P = T \circ Q \circ S,$$

T 和 S 分别为两个可逆的仿射变换。称寻找从 (Q) 到 (P) 同构的 (T, S) 的问题为 IP 问题。

此外, 基于 Hash 链的签名体制所基于的困难问题是求解 Hash 函数的逆计算及碰撞性。其中, 基于编码问题的密码体制、基于格问题的密码体制、基于多变量问题的密码体制及基于 Hash 问题的密码体制被称为后量子密码技术, 基于这类问题的密码体制被认为是可以抵抗量子计算攻击的。

2.2 可证明安全性

作为一种“归约”的方法^[20-21], 可证明安全首先要确定密码体制的安全目标, 然后定义一个合理的安全模型, 同时指出密码方案的安全性与安全模型之间的归约关系。目前, 语义安全性以及非延展安全性是公钥密码学中被广泛接受的两种安全性定义。在 1984 年, Goldwasser 和 Micali 首次提出了语义安全性的定义, 也称为不可区分安全性, 主要指攻击者没有能力从给定的密文中得到任何关于明文的信息^[22]。在 1991 年, Dolev, Dwork 和 Naor 提出了非延展安全性的定义, 主要是指攻击者无法基于给定的密文, 建立和明文意义相关的明文的密文^[23]。特别注意的是, 在大多数重要且吸引人的问题上, 不可区分安全性与非延展安全性往往是等价的。

最近几年, 可证明安全性得到了非常广泛地研究, 它可以用于证明所设计的密码算法的有效性。对于公钥加密方案和数字签名, 我们可以研究其安全需求, 然后建立合适的安全模型。作为目前最有效的证明方法之一, 随机预言机模型 (Random Ora-

cle Model, ROM) 得到了很好的应用。现在, 一个算法想要被人们广泛地接受, 就需要在某些合理的安全模型中被证明是安全的。正如我们所知, 对于一个安全的密码算法, 它的安全性最终要归约到一个 NP 问题上, 真正的安全性证明还难以达到这一程度。然而, 已有的安全模型和假设可以帮助我们更好的解释新设计的密码方案的安全性, 确认基本设计的正确性。

1993 年, Bellare 和 Rogaway 从 Fiat 和 Shamir 的建议中提出了随机预言模型的概念^[24]。在随机预言模型中, 任何具体的对象都被看作是随机对象。该模型允许人们把参数归约到相应的计算, 比如哈希函数被作为一个随机预言的返回值, 也就是每一个新的查询会得到一个随机的应答。敌手被视为一个程序, 归约将把敌手作为一个子程序来调用, 最终推出该子程序与数学假设相矛盾, 比如 RSA 是单向算法这一假设。由于在安全证明的最后, 往往需要分析敌手成功的优势, 因此概率理论在随机预言模型中有着广泛的应用。另一方面, 关于随机预言模型也存在着争议, 这是由于哈希函数是确定函数, 不能总是返回随机结果。尽管如此, 随机预言模型下的安全性可以保证一个密码方案没有明显的设计缺陷。

2.3 数字签名体制

数字签名体制^[4-5, 25]属于公钥密码技术的主要分支之一, 是解决消息源认证、消息完整性认证和不可否认性的密码技术。加密技术能够解决被传递的信息不被窃听, 但不能使得接收者判断收到的信息 (明文或密文) 其来源的正确性和消息的完整性 (没有被攻击者篡改), 同时也不能防止消息的发送者对其传递消息的行为的抵赖性。数字签名正是解决这类问题的公钥密码理论技术。

数字签名的结构与公钥加密体制的结构是类似的。在数字签名体制中, 其密钥包含公钥/私钥对, 公钥是公开的密钥, 私钥是签名者拥有的私钥。常用的签名算法包括 RSA 签名算法、基于椭圆曲线的数字签名算法、基于离散对数的签名算法等。通常, 签名算法的安全性原理与公钥加密体制的安全性原理一样, 是建立在某个困难问题的基础上。目前能够用于构造公钥加密算法的困难问题, 其大多数也可以用于构造数字签名算法。随着应用需求的变化, 数字签名的变形种类也在发展, 比如群签名、环签名、代理签名、盲签名等。

群签名是数字签名中最受青睐的研究方向之一。在 Chaum 于 1991 年提出群签名技术之后^[26], 学术界出现了大量的群签名方案, 其中典型的群签

名变形包括“环签名”、代理签名、盲签名、可连接的环签名、代理忙签名等技术^[27-33]。文^[34-36]等研究了基于线性反馈移位寄存器(Linear Feedback Shift Register, LFSR)和基于编码问题的群签名。

2.4 基于属性的密码学

基于属性的密码学属于一种特殊的公钥密码学,它是由基于身份的密码学发展而来的。传统的公钥密码学由于涉及到证书管理,因此在实际应用中存在效率缺陷。为了消除证书管理所带来的性能瓶颈,基于身份的密码学被提出。在基于身份的体制中,用户不再需要通过数字证书对自己的身份和公钥信息进行绑定,而是直接把与自己身份相关的公开信息作为公钥,私钥则由可信的私钥生成中心来颁发。

然而,不管是传统的公钥密码学还是基于身份的密码学,就加密技术而言,只能实现一对一的加密模式,因此不适用于数据共享的环境。随着云计算和在线社交网络技术的迅速发展,通过第三方服务提供商进行数据共享越来越经济和方便,越来越多的个人和组织愿意将自己的数据外包给第三方服务器来存储。特别地,基于属性的加密非常具有应用前景,可用于实现针对云存储的细粒度访问控制系统。文^[37]第一次提出基于属性的加密及其构造。基于属性的加密包括密文策略下基于属性的加密和密钥策略下基于属性的加密。相比而言,密文策略下基于属性的加密有着更广阔的应用前景,这是由于密文策略下基于属性的加密可以把访问策略的决定权放在数据拥有者手中。

3 密码协议

密码学的用途是解决人们生活遇到的许多问题。这些问题通过合理的使用密码算法来解决。密码学要解决的问题是面临第三方攻击的通信安全问题,这些问题包括信息机密性、信息来源的可靠性、信息的完整性、通信实体的完整性、通信实体的欺诈性等。利用密码算法解决这些问题,需要对密码算法采取一系列步骤进行实施,最后达到解决问题的目的,这一系列步骤就称为密码协议。

可见,所谓密码协议指的是在完成某项安全通信任务的过程中,通信各主体需要采用密码技术进行的一系列步骤。密码协议的目的不仅仅是为了简单的秘密性,参与协议的各方可能为了计算一个数值需要共享它们的秘密部分、共同产生随机序列、确定互相的身份、或同时签署合同等。

3.1 认证协议

认证协议是一个认证过程,是两方或多方通信实体为达到向对方证明自己拥有某种属性进行的一系列步骤。认证协议可以分为三个子类型:数据源认证、实体认证、密钥建立的认证。

3.1.1 数据源认证

数据源认证与数据完整性认证无法完全隔离开来,逻辑上来讲,被篡改过的消息可以认为不是来自最初消息源。不过,这两个概念差别很大,且用途功能不同。数据源认证协议包含以下特征。

(1) 包含从某个声称的消息源到接收者的传输过程,该接收者在接收时会验证消息。

(2) 接收方执行消息验证的目的在于确认消息发送者的身份,防止敌手冒充合法用户发送消息。

(3) 接收方执行消息验证的目的还在于确认收到的消息是否完整(离开消息源之后没有被篡改)。

(4) 验证的进一步目的是验证消息的鲜活性(消息是否第一次从正确的消息源被发送出来的)。

3.1.2 实体认证

所谓实体认证指的是依照认证协议进行通信的一个过程,基于实体认证技术,一个通信实体可以向另一个通信实体证实自己的身份并得到对方的确认。认证协议的一个重要目标就是实体认证。

3.1.3 密钥建立认证协议

认证密钥建立协议^[38]主要实现以下功能:为参与某具体协议的若干个参与者实现身份认证,并为这些参与者建立一个新的共享密钥,用于后续的安全通信。作为应用最为广泛的网络通信协议之一,认证密钥建立协议所生成的会话密钥可以构建安全通道,保证应用层上的后续通信的安全。当然,该协议也可以与公钥密码体制一起使用,同时实现机密性和认证性。密钥建立协议通常分为密钥分发协议和密钥交换协议(或密钥协商)等。我们经常用到的认证密钥协议包括 Kerberos 认证协议、Needham-Schroeder 认证协议等。在密钥建立协议中会包含对实体认证和数据源认证。认证协议也可用于无线网络中安全切换认证,在无线网络中,一个终端用户可能由于实际通信需求,需要切换到另一个基站所覆盖的范围内,这个用户就需要和新的接入点进行相互认证和密钥协商。

3.2 协议面临的典型攻击

在密码技术领域,认证协议会面临多种攻击方法,这就是认证协议的安全性问题难以解决的原因所在。正如毛文波博士在其书中指出:对认证协议或认证的密钥建立协议的成功攻击,通常并不是指攻破该协议的密码算法,相反,它通常是指攻击

者能够以某种未授权并且不被察觉的方式获得某种密码信任证件或者破坏某种密码服务,同时不用破坏某种密码算法。这是由于密码设计的错误,而不是密码算法的问题。密码协议面临的典型攻击众多。

3.2.1 消息重放攻击

攻击者预先记录某个协议先前的某次运行中的某条消息,然后在协议新的运行中重放(重新发送)记录的消息,由于认证协议的目标是建立通信方之间的真实通信,并且该目标通常是通过多方直接交换新鲜的消息来实现,所以协议之间的消息重发会导致通信方的错误判断,从而导致通信者之间的不真实的通信,且通信者察觉不到。

3.2.2 中间人攻击

中间人攻击在本质上众所周知的“象棋大师问题”,它主要针对缺乏双方认证的通信协议中,在攻击过程中,攻击者能够把协议的参与者所提出的困难问题提交给另一个参与者来回答,然后把答案交给原来提问者,反之亦然。

3.2.3 平行会话攻击

在攻击者的安排下,一个协议的多个运行并发执行,在此过程中,攻击者能够从一个运行中得到另外某个运行中的困难问题答案,从而达到攻击的目的。

3.2.4 交错攻击

某个协议的两次或多次运行在攻击者的特意安排下按交织的方式执行。在这种模式下,攻击者可以合成其需要的特定消息并在某个运行中进行传送,以便得到某主体应答消息,此应答消息又被用于另外运行的协议中,如此交错运行,最终达到其攻击目的。

在协议的攻击类型中,还有其它更多的攻击方法,比如姓名遗漏攻击、类型缺陷攻击、密码服务滥用攻击等。对密码协议的攻击无法穷尽,除了人们发现或已知的很多攻击之外,可能还存在很多人们没有发现的潜在攻击。由上述针对各种密码协议的攻击方法来看,密码协议所面临的攻击方式是通常是多种多样的,常常会以令人非常吃惊的方式出现。如何设计安全的密码协议或如何检测一个密码协议是否安全是密码技术中的一个严峻课题。

3.3 安全协议分析方法概述

由于认证协议会面临诸多已知攻击及未知的攻击,因此,针对认证协议的安全性分析也成为密码研究中的一个特别重要的研究方向。目前已有的关于安全协议的分析方法主要可以归纳为4种。

3.3.1 基于逻辑推理的分析方法

1989年,文[39]提出了以其作者(Burrows, Abadi 和 Needham)命名的BAN逻辑,成为逻辑分析的典型代表。作为一个开创性工作,BAN逻辑首次对基于逻辑推理所设计的密码协议进行了形式化分析。在BAN逻辑中,各个参与者在最初始时刻的知识有了形式化定义,参与者的职责也同样得到了形式化。BAN逻辑通过信息的发送和接收等协议步骤可以得到新知识,再利用推理规则获取最终的知识。当协议执行完成后,如果最终得到的知识和信任语句集中没有目标知识和信任的相应语句时,就表明所设计的协议是不安全的,存在缺陷。具体的逻辑分析步骤如下。

(1) 协议理想化:通过BAN逻辑语言对实际协议的所有步骤进行描述。

(2) 确定初始假设:协议运行开始时的信仰假设和状态假设。

(3) 确定断言:所谓确定断言就是将相关逻辑公式附加给协议的语句。

(4) 逻辑化推理:所谓逻辑化推理就是利用推理规则,基于假设和断言来得到参与者最终的信仰。最后,对最终得到的逻辑结果判断,检查所设计的协议是否达到设计之初的目标。

3.3.2 基于模型检验的分析方法

模型检验技术是一种适用于有限状态系统的自动化分析技术,实际上也是密码协议的一种自动验证工具。从协议的初始状态开始,模型检验(Model Checking)技术就对协议主体和潜在攻击者的所有可能的执行路径进行状态搜索,以确定是否存在错误状态。这种技术方法进行密码协议分析建模是以进程代数、Dolev-Yao模型等为理论基础的。1996年,基于通信顺序进程(Communication Sequential Processes, CSP)方法和模型检验技术, Lowe实现了密码协议的形式化分析。基于CSP模型以及CSP模型的失败差异细化(Failures-Divergences Refinement, FDR)检验工具, Lowe对Needham-Schroeder认证协议进行了分析,并发现了针对该协议的一个可行的攻击。其它类似的方法包括Interrogator系统、FDR模型检验工具和NRL(Naval Research Laboratory)协议分析器等。模型检验技术需要面临的难题是如何恰当地把安全协议用对应的分析语言描述。由于该方法是一种状态搜索的过程,当协议稍微复杂时,会面临状态爆炸问题。此外,这种方法的分析过程与攻击者能力的刻画和密码协议的形式化都紧密相关,而攻击者的行为方式却在不断地发展变化。

3.3.3 基于定理证明的分析方法

就基于定理证明的分析方法来说,串空间(Strand Space)方法非常重要。串空间方法是Thayer、Herzog和Guttman于1998年提出并用于密码协议分析的^[40]。多个strand的集合构成串空间,strand是一个线性结构,由发送和接收的消息组成,是协议主体或者攻击者的行为事件的一个序列。对于协议的一个诚实主体而言,它在协议一次运行中的行为可以基于一个strand来表示,不同strand表示不同主体的行为。特别地,一个主体在某个时间段里参加了多次协议运行也用不同的strand来表示。对于攻击者而言,它所获知的消息的发送和接收行为共同组成其strand中的行为。

3.3.4 密码学可证明安全性分析方法

该方法使用现代密码学中可证明安全性的理论,在复杂性理论的框架下提供协议安全证明,是一种规约式证明,把协议的安全性规约到某特定的已知难题。在一些特定框架下能够给出密码协议的安全性证明。

4 密码学的发展趋势和研究方向

4.1 密码学发展趋势

密码学已经是人们生活中不可缺少的安全技术。比如银行业务及个人电子支付、企业电子报税、社保系统安全、物联网安全识别与隐私保护技术、电子政务、电子拍卖、电子选举等业务。人们一方面要设计新的算法以便满足各种新应用的挑战,同时又要面对密码分析的新技术以便保证密码安全性。然而,除了编码与破译,密码学还涉及到安全协议设计和安全管理等内容。特别地,密码学的发展也促进了许多新技术的诞生。新技术的推广应用以及计算能力的不断提升将会给密码学带来新的机遇和挑战,因此,密码学的研究应该紧跟时代的要求。综观全局,密码学的发展呈现出如下趋势。

(1) 标准化趋势

密码的标准化是密码理论与技术不断发展的结晶和原动力,包括AES、安全哈希算法(Secure Hash Algorithm 3, SHA3)、以及eSTREAM计划和NESSE计划等都极大地推动了密码学研究。

(2) 公理化趋势

在设计密码算法的过程中,保证算法的可证明安全性是非常有吸引力的,密码协议的形式化分析方法、安全多方计算理论、可证明安全性理论以及零知识证明等仍将是密码协议研究中的主流方向。

(3) 面向社会的实用化趋势

随着电子政务和电子商务的出现,密码技术的实际应用面临着新的机遇和挑战。基于生物特征的密码技术是目前研究的一个热点,由于实际应用的需要,它也是未来的一个重要研究方向。此外,轻量级密码技术也已成为当前非常受关注的一个研究方向。

4.2 密码学研究方向

随着通信技术的迅猛发展和信息时代的到来,密码学发展面临着前所未有的挑战和机遇。在密码理论方面进行创新,努力开辟密码领域的新篇章才应是我们的追求。对于实际应用而言,设计的密码算法不仅要在理论上是可证明安全的,同时也要在效率上是可行的。因此,随着计算速度的不断提高和针对密码的不断增长的需求,密码分析和攻击手段也在不断进步,发展密码理论是一个非常迫切的实际需求,这给密码学的发展指出了新的研究方向。

4.2.1 各种密码算法分析技术

密码算法分析技术是密码学永久的研究方向,这是因为我们的密码算法大多都是计算安全的,其安全性是建立在当前的攻击技术及计算资源的有限性。随着攻击技术的发展和计算资源的变化(如计算机CPU能力的提高等),对密码算法的攻击能力也在变化,只有了解最强的攻击技术,才能保证密码算法的安全使用或设计更安全的算法。

4.2.2 轻量级密码技术

轻量级密码技术是为一些资源受限的环境下设计的密码体制,即计算能力弱、存储资源小的设备,比如在物联网的标签、射频识别(Radio Frequency Identification, RFID)安全技术等。轻量级密码技术包含轻量级对称密码算法、轻量级公钥密码算法、轻量级认证技术、及轻量级Hash算法等,此外研究轻量级密码的硬件实现技术也是人们关注的重要课题之一。

4.2.3 DNA密码

DNA密码技术的特点是把脱氧核糖核酸(Deoxyribose Nucleic Acid, DNA)作为信息载体,以生物技术为实现手段,挖掘DNA所固有的优点,如高存储密度和高并行性,进而实现加密、签名等密码功能。与传统的密码以及研制中的量子密码相比,DNA密码既有优势也有劣势,在未来的应用中可以互相补充。研究DNA密码的主要困难在于缺乏安全理论支撑以及有效的实现方法。

4.2.4 函数加密

随着云计算技术的迅速发展,通过第三方服务提供商进行数据共享越来越经济和方便。尽管这

些新的技术和服 务非常有吸引力,但是使用这些服务的个人和组织仍然非常担忧自己的隐私和数据的安全。为了防止自己的数据遭受潜在的威胁,人们必须确保自己的机密数据只能被授权的用户获得。特别的,具有不同属性和角色的用户应该被授予不同等级的访问权限,即所谓的细粒度访问和共享数据。这些目标可以通过函数加密来实现,包括基于属性的加密、内积加密和谓词加密等具体的加密技术^[41-45]。特别地,可以考虑隐私保护、审计、追踪等特性。

4.2.5 后量子密码技术

在量子计算模型下,基于大整数分解和基于离散对数问题的密码体制将不再安全,人们需要找到能够代替这类经典算法的密码体制,希望能够抵抗量子计算攻击。目前有四类公钥密码体制被认为是在量子计算模型下是安全的:分别是基于纠错码的公钥密码体制、基于多变量的公钥密码体制、基于 Hash 树的公钥密码体制和基于格问题的公钥密码体制。这类密码体制的缺陷是密钥规模比较大,人们希望能够设计出更安全且高效的抗量子计算的密码体制。

4.2.6 量子密码技术

量子密码技术是以量子法则(量子编码规则)为基础,利用量子态作为符号而实现的密码技术。量子密钥分配是该领域的主要研究方向。其优点是量子信息在传送过程中如果受到扰动,是可以被检测的。目前也有涉及到量子保密体制、量子认证等方面的密码技术,但这些还只是处在不成熟的初探阶段。

5 结束语

随着人类科学技术水平的不断进步,特别是计算技术的突飞猛进,密码学的研究正面临着前所未有的发展机遇。本文详细介绍了密码学及其应用研究的发展状况,说明了在密码理论创新和实际应用等方面进行创造性思维的必要性和迫切性,并指出了密码学未来的发展趋势和几个主要研究方向。

参 考 文 献

- [1] Shannon C E. Communication theory of secrecy systems[J]. Bell System Technical Journal, 1949, 27(4): 656-715.
- [2] Diffie W, Hellman M E. New directions in cryptography[J]. IEEE Transactions on Information Theory, 1976, 22(6): 644-654.
- [3] Hohenberger S, Sahai A, Waters B. Full domain hash from (leveled) multilinear maps and identity-based aggregate signatures[C]//Advances in Cryptology-CRYPTO'13. Berlin: Springer-Verlag, 2013: 494-512.
- [4] Bellare M, Namprempre C, Neven G. Security proofs for identity-based identification and signature schemes[J]. Journal of Cryptology, 2009, 22(1): 1-61.
- [5] Bellare M, Kiltz E, Peikert C. Identity-Based (lossy) trapdoor functions and applications[C]//Advances in Cryptology EUROCRYPT'12. Berlin: Springer-Verlag, 2012: 228-245.
- [6] 王育民, 刘建伟. 通信网的安全: 理论与技术[M]. 西安: 西安电子科技大学出版社, 1999: 231-232.
- [7] 郑东, 李祥学, 黄征. 密码学: 密码算法与协议[M]. 北京: 电子工业出版社, 2009: 45-46.
- [8] Stehle D, Steinfeld R. Making NTRU as secure as worst-case problems over ideal lattices[C]//Advances in Cryptology EUROCRYPT'11. Berlin: Springer, 2011: 27-47.
- [9] Cho J Y. Linear cryptanalysis of reduced-round PRESENT[C]//Topics in Cryptology-CT-RSA'10. Berlin: Springer, 2010: 302-317.
- [10] Biham E, Shamir A. Differential cryptanalysis of DES-like cryptosystems [C]//Advances in Cryptology CRYPTO'90. Berlin: Springer-Verlag, 1991: 63-72.
- [11] Biham E, Shamir A. Differential cryptanalysis of FEAL and N-hash[C]//Advances in Cryptology EUROCRYPT'91. Berlin: Springer-Verlag, 1991: 1-16.
- [12] Biham E, Shamir A. Differential cryptanalysis of snefru, khafre, REDOC, LOKI, and lucifer [C]//Advances in Cryptology-CRYPTO'91. Berlin: Springer-Verlag, 1992: 156-171.
- [13] Biham E, Shamir A. Differential fault analysis of secret key cryptosystems[C]//Advances in Cryptology CRYPTO'97. Berlin: Springer-Verlag, 1997: 513-525.
- [14] Odlyzko A M. Discrete logarithms in finite fields and their cryptographic significance [C]//Advances in Cryptology EUROCRYPT'84. Berlin: Springer-Verlag, 1985: 224-314.
- [15] McEliece R J. A public key cryptosystem based on algebraic coding theory[R]//Deep Space Network Progress Report Jet Propulsion Laboratory. California: California Institute of Technology, 1978: 42-44.
- [16] Shamir A. Identity-based cryptosystems and signature schemes[C]//Advances in Cryptology-CRYPTO'84. Berlin: Springer-Verlag. 1985: 47-53.
- [17] Bellare M, Waters B, Yilek S. Identity-based encryption secure against selective opening attack [C]//Theory of Cryptography. Berlin: Springer-Verlag. 2011: 235-252.
- [18] Wolf C, Preneel B. Taxonomy of public key schemes based on the problem of multivariate quadratic equations. Manuscript, E-Print Archive[EB/OL]. (2005-

- 05-12) [2003-10-08]. <http://citeseerx.ist.psu.edu/viewdoc/download?doi=10.1.1.59.2940&rep=rep1&type=pdf>.
- [19] Patarin J. Hidden fields equations (HFE) and isomorphisms of polynomials (IP): Two new families of asymmetric algorithms[C]//Advances in Cryptology EUROCRYPT'96. Berlin: Springer-Verlag, 1996: 33-48.
- [20] Brakerski Z, Goldwasser S. Circular and leakage resilient public-key encryption under subgroup indistinguishability[C]//Advances in Cryptology CRYPTO'10. Berlin: Springer-Verlag, 2010: 1-20.
- [21] Dodis Y, Wichs D. Non-malleable extractors and symmetric key cryptography from weak secrets[C]//Proceedings of the 41st annual ACM symposium on Theory of computing. New York: ACM, 2009: 601-610.
- [22] Goldwasser S, Micali S. Probabilistic encryption[J]. Journal of Computer and System Sciences, 1984, 28(2):270-299.
- [23] Dolev D, Dwork C, Naor M. Non-malleable cryptography[C]//Preliminary Version in Proceedings of the 23rd Annual Symposium on the Theory of Computing. New York: ACM, 1991:1-24.
- [24] Bellare M, Rogaway P. Entity Authentication and key distribution CRYPTO'93[C]//Advances in Cryptology. Berlin: Springer-Verlag, 1993: 110-125.
- [25] Mashatan A, Ouafi K. Forgery-resilience for digital signature schemes[C]//Proceedings of the 7th ACM Symposium on Information, Computer and Communications Security. New York: ACM, 2012: 24-25.
- [26] Chaum D, Van H E. Group Signatures[C]//Advances in Cryptology-EUROCRYPT'91. Berlin: Springer-Verlag, 1991:257-265.
- [27] Aguilar M C, Cayrel P, Gaborit P, et al. A new efficient threshold ring signature scheme based on coding theory[J]. IEEE Transactions on Information Theory, 2009, 57(7):4833-4842.
- [28] Wen Xiaojun, Chen Yongzhi, Fang Junbin. An inter-bank E-payment protocol based on quantum proxy blind signature[J]. Quantum Information Processing, 2013, 12(1):549-558.
- [29] Fujisaki, Eiichiro. Sub-linear size traceable ring signatures without random oracles[J]. IEICE Transactions on Fundamentals of Electronics, Communications and Computer Sciences, 2012, 95(1):151-166.
- [30] Boldyreva A, Palacio A, Warinschi B. Secure proxy signature schemes for delegation of signing rights[J]. Journal of Cryptology, 2012, 25(1):57-115.
- [31] Verma G K. A Proxy Blind Signature Scheme over Braid Groups[J]. IJ Network Security, 2009, 0(3):214-217.
- [32] Lu S, Ostrovsky R, Sahai A, et al. Sequential aggregate signatures, multisignatures, and verifiably encrypted signatures without random oracles[J]. Journal of Cryptology, 2013, 26(1):1-34.
- [33] Zhang Lei, Zhang futai, Wu qianhong. Delegation of signing rights using certificateless proxy signatures[J]. Information Sciences, 2012, 184(1):198-309.
- [34] Zheng Dong, Li Xiangxue, Chen Kkefei. Code-based ring signature scheme[J]. International Journal of Network Security, 2007, 5(2): 154-157.
- [35] Zheng Dong, Victor K W, Chen Kefei. A GDH group-based signature scheme with linkability[J]. J IEE Communications, 2006, 153(5): 539-644.
- [36] Zheng Dong, Li Xiangxue, Chen Kefei. LFSR-based ring signature scheme[J]. Chinese Journal of Electronics, 2007, 16(3): 397-400.
- [37] Sahai A, Waters B. Fuzzy identity-based encryption [C]//Advances in Cryptology EUROCRYPT'05. Berlin: Springer-Verlag, 2005: 457-473.
- [38] Dodis Y, Kanukurthi B, Katz J, et al. Robust fuzzy extractors and authenticated key agreement from close secrets[J]. IEEE Transactions on Information Theory, 2012, 58(9): 6207-6222.
- [39] Burrows M, Abadi M, Needham R M. A logic of authentication[J]. Mathematical and Physical Sciences, 1989, 426(1871):233-271.
- [40] Fabrega F T, Herzog J C, Guttman J D. Strand spaces: why is a security protocol correct[C]//Proceedings of IEEE Symposium on Security and Privacy. New York: IEEE, 1998:160-171.
- [41] Boneh D, Sahai A, Waters B. Functional encryption: a new vision for public-key cryptography[J]. Communications of the ACM, 2012, 55(11): 56-64.
- [42] Akinyele J A, Pagano M W, Green M D, et al. Securing electronic medical records using attribute-based encryption on mobile devices[C]//Proceedings of the 1st ACM workshop on Security and privacy in smartphones and mobile devices. New York: ACM, 2011: 75-86.
- [43] Luo Song, Hu Jianbin, Chen Zhong. Ciphertext policy attribute-based proxy re-encryption[C]//Proceedings of the International Conference on Information and communications Security, ICICS'10. Berlin: Springer-Verlag, 2010: 401-415.
- [44] Zhang Yinghui, Chen Xiaofeng, Li Jin, et al. Anonymous attribute-based encryption supporting efficient decryption test[C]//Proceedings of the 8th ACM SIGSAC symposium on Information, computer and communications security. New York: ACM, 2013: 511-516.
- [45] Chase M, Chow S S. Improving privacy and security in multi-authority attribute-based encryption[C]//Proceedings of the 16th ACM conference on Computer and communications security, CCS'09. New York: ACM, 2009: 121-130.

[责任编辑:王辉]